

win-reverse V3.5 【AI逆向研究所】

Windows 平台专业逆向工程技能框架：面向 AI Agent 的**执行控制面**，不是传统知识库。框架负责触发识别、task-local 初始化、阶段门禁、专题路由与验证完整性保护；细节规则按需下沉到 `references/` 与 `docs/reference/`，机器契约单源收敛在 `SKILL.md` 的 GENERATED 块与 `docs/reference/acceptance-criteria.md`。

覆盖 PE/EXE/DLL/SYS/.NET/WOW64/VMP/Themida/Enigma 等目标形态，含壳与脱壳、抗分析、.NET/CLR、驱动、Frida 运行时、TLS/网络、Loader/注入、配置恢复、UI 消息流、IPC/持久化、内存取证、Web 套壳分流，以及游戏逆向 / 恶意软件分析 / 应用协议还原等扩展领域，并支持模拟真实 Windows 高级逆向场景的多专题 drill 演练。

定位与设计

- **控制面而非知识库**：`SKILL.md` 是唯一必读最小集，承载触发面、硬约束与 GENERATED 词表；专题细节全部下沉，命中时按需补读。
- **文档四层**：`SKILL.md` (always-loaded 单源) → `docs/guides/` (上手手册，唯一篇目 minimal-usage-manual) → `docs/reference/` (机制规格：workflow / acceptance / multi-agent / output-contract 等) → `references/` (专题协议与 playbook)。
- **文档即产物**：GENERATED 块由 `tools/docs/sync-doc-facts.mjs` 从代码常量与 topic 注册表单源生成，勿手改；漂移会被 `check-doc-facts` 拦截，`npm run sync:doc-facts` 再生成。
- **诚实边界**：成熟度只描述本仓库内的执行契约、验证口径与专题产物保证，不等同于“所有真实目标或高对抗样本都已完成实战回归”。文本约束对“不读取约束”的运行环境无效，此时 task 门禁失效，只能靠 Agent 自律。

适用与不适用

必须触发：逆向 PE/EXE/DLL/SYS/.NET/Mixed-Mode；壳 / 反调试 / 抗分析；

Electron/CEF/WebView2；驱动 / IOCTL / Frida；TLS/网络 / SSL Pinning；Loader / 注入；IPC / 持久化；配置 / 许可证恢复；Windows CTF；游戏逆向；恶意软件分析；协议 / 签名还原；延续既有任务。

不属于本技能：普通 Windows 开发、未授权漏洞利用、Android 逆向、非 Windows 场景逆向。

快速分诊：单一问题、一轮静态可答、不涉及动态执行时可直接回复；命中 Electron/CEF、壳/脱壳、协议/签名、多阶段验证、补丁或 hook 时，必须先 `task-start` 建立 task-local——未建 task-local 前禁止调用 IDA/radare2/x64dbg 等分析工具。

任务生命周期

叙事闭环：`Init → Sync → Advance → Observe → Capture → Rebuild → Patch → PureExtraction → Port → Close`。其中 `Init/Sync/Advance/Close` 是工具命令叙事；机器合法 `task.phase` 只有 6 个值 (`Observe` / `Capture` / `Rebuild` / `Patch` / `PureExtraction` / `Port`，词表见 `SKILL.md` GENERATED `phase-vocabulary` 块)，阶段切换走 `task-advance --to=<phase>`，只前进不回退。

任务-local 关键文件：

文件	角色
task.json	契约与状态真源（首轮锁定契约五字段，此后改动留 contract-change-log）
report.md	唯一强制文档：收口任务总结（骨架由 task-init 预生成）
state/route-state.json	恢复真源（可选续跑骨架）；route-plan.md / clues.md 为派生视图
run/verify-once.mjs	框架预生成自查线束，禁止覆写
run/	证据、脚本、备份 manifest、崩溃诊断等任务产物落点

契约五字段（task-sync 前锁定，机器校验）：target / objective / deliverableTier / completionCriteria / boundaries。completionCriteria 仅接受对象形 {"text":..., "status": "pending"}，逐条判据须带合法 evidenceRefs（task-local 真实文件 / 用户确认:<原文> / call_xxx+excerpt 三选一）。deliverableTier 五枚举：evidence / hook-script / patch / protocol-doc / pure-algorithm；evidence 与 protocol-doc 免 run/run-local.mjs 占位要求，其余 closeout 门禁对全部 tier 一视同仁。

收口验收模型（report-only）

- 过程零落盘义务：不要求 investigation / plan / assumptions 或任何专题 notes 过程文档，也没有相位出口文档门禁；state/ 三件套是可选续跑骨架，写不写不影响收口判定。
- 唯一强制文档 = report.md：收口时按骨架章节一次性写全——任务摘要 / 实现路径 / 逆向思路 / 任务难点 / 坑点与经验 / 验证证据 / 专题发现 / 未竟事项。机器校验全篇实质内容达标（非模板复述），「任务摘要 / 实现路径 / 验证证据」三节必备；命中 topic 时「专题发现」须有对应专题小节（关键词 + 最小字符数谓词，见各 topics/<key>/topic.json 的 formalValidation）；closeoutMode=partial/infeasible 时「未竟事项」必填。
- 框架对 report.md 只读不写：除缺失时补骨架外不做任何节注入（dry-run 与正式 close 均字节级不变）。
- 收口流程：正式 task-close 前先 task-close --dry-run 预检（跑全部门禁但不归档不清理），把剩余 finding 一次修完再收口；开工提示里的 [closeout-obligations] 清单是义务的事前版，按清单推进可把 dry-run 剩余 finding 压到接近零。

硬门禁与安全纪律

- 契约锁：task.json 五字段首轮锁定；手改 task.json 后必跑 JSON.parse 自检。
- 证据硬门禁：没有截图、命令输出、调试输出或用户确认，不得声明完成；脚本无报错、hook 已注入、文件已修改、代码"逻辑上应该可行"都不是证据。evidenceRefs 必须指向任务目录内真实存在、非模板占位的文件。
- 备份断路器：目标文件修改前必须写 .clean.bak 并登记 run/backup-manifest.md（原始绝对路径 + SHA256）；备份与原文件哈希不一致时 task-advance 阻断推进，受控修改需显式 run/hash_mismatch_authorized.flag。

- **crash 门禁**：静默闪退 / 无日志退出时停止修改目标，写 `run/crash-diagnostics.md` (≥200 字符，含 EIP/RIP、ExceptionCode、0x 地址、调试器输出等特征)，`task-advance` 合规检查通过后再继续。
- **方案否决记忆**：用户否决的方案族写入 `task.json.userRejectedApproaches`，后续不得复活。
- **重工具调用判级 / 止损分级**：IDA/r2/CE 等 MCP 重型调用按「时序+错误层」三分判级 (有毒 / 通道不可用 / 业务报错)，降级阶梯与只读探活白名单写死于 `SKILL.md`；转向按「缩范围 → 换工具/通道 → 换路线 → 升级协作」四级阶梯。细则见 `references/fallbacks.md` 与 `references/anti-shortcut-system.md`。
- **大输出纪律**：超 ~8KB 的 MCP/命令输出一律落盘 `run/` 后摘要读取；截图只走 `tools/verify/capture-screen.ps1` (截取时即缩放 ≤1280 宽)，禁止直接 Read 原始全屏截图。

多 Agent 协作 (multi 模式 · 显式 opt-in)

新任务默认 single；确需协作在 `task-init` 传 `--execution-model=multi` (init 会打印能力自检清单：宿主 subagent 派发通道、IDB 独占文件锁、每相位约 +5 步簿记开销)。

```
node "<SKILL_BASE>/tools/task/task-dispatch.mjs" <task-id> --kind=worker --focus="<本包工作范围>" # 派工
node "<SKILL_BASE>/tools/task/task-dispatch.mjs" <task-id> --kind=audit --audit-kind=phase-gate # 派审
node "<SKILL_BASE>/tools/task/task-dispatch.mjs" <task-id> --collect=audit-NNN
# verdict 入账
node "<SKILL_BASE>/tools/task/task-dispatch.mjs" <task-id> --ledger
# 查看影子账本
```

- **角色**：Orchestrator (编排、派单、推进与收口) / Worker (只执行派单包内工作并回写 Worker Report) / Auditor (只审计，落裸行 `verdict: PASS|VIOLATION`)。
- **节奏**：派工 → 完工回写 → 派审 → 入账 → `task-advance` 才放行；`task-close` 另需 `completion-claim` 审计 PASS。
- **证据链**：包/审计文件必须携带「通道标记；判定事件落在 `append-only` 哈希链影子账本 (`~/.winreverse/ledger/.jsonl`，可用 `WINREVERSELEDGER_ROOT` 改道)。手写 `state/packages/` 伪证 (`package-not-dispatched`) 与先干活后补签字 (`work-before-dispatch`) 会被门禁拦截。
- single/legacy 任务协作门禁整体跳过，不建账本；硬门禁 (契约锁 / 哈希断路器 / crash 门禁 / close 咽喉) 不受影响。协议详见 `docs/reference/multi-agent-orchestration.md` 与 `agents/` 三角色定义。

动态验证线束 (GUI / 协议重放)

- `tools/verify/gui-drive.ps1.template`：GUI 动态验证线束模板 (v3)。合成事件优先 (UIA ValuePattern 写入 + InvokePattern 点击)，连续 `-SyntheticRetryLimit` (默认 2) 次失败自动升级真实键鼠保底；五断言内置——主屏可视区拉回、前台窗口断言、Y 序控件定位+写入读回、保底切

换、`#32770` 弹窗 Static 正文读取；读毕弹窗即 WM_CLOSE 排空防模态阻塞，邻近 Static 标签锚定控件身份，支持 `-SuccessProbe` 成功信号探针挂点。复制到任务 `run/gui-drive.ps1` 后按目标改控件定位符，干跑校验：`pwsh -File run/gui-drive.ps1 -ExePath <样例> -ValidateOnly`。

- `run/run-local.mjs` (任务内参数化骨架)：`--mode=algo --input=run/pure-*.js` 跑算法复现；`--mode=replay --script=run/replay.ps1` 跑协议回放 (内置 pwsh STA 兼容 spawnSync 写法)。
- 辅助脚本：`tools/verify/capture-screen.ps1` (缩放截图)、`tools/verify/ps-read-memory.ps1` (PowerShell 只读内存，CE 通道失效时的降级阶梯成员)、`tools/verify/enum-windows.ps1` (窗口枚举)。

专题体系与成熟度

专题以 `topics/<key>/topic.json` 注册 (signals / routeTrack / 协议文档 / formalValidation / requiredChecks)，`docs/reference/capability-matrix.md` 是生成 registry 视图。当前成熟度分布：

- `synthetic-e2e` (17): `anti-analysis`, `app-protocol`, `config-recovery`, `dotnet`, `driver`, `exception-runtime`, `frida-hooking`, `ipc-persistence`, `loader-injection`, `memory-forensics`, `mixed-mode-interop`, `packer-unpack`, `protection-bypass`, `static-triage`, `tls-network`, `ui-runtime`, `web-shell-triage`
- `guided` (0): none published yet
- `closed-loop` (0): none published yet
- `reference-only` (3): `ctf`, `game-reverse`, `malware-analysis`
- **synthetic-e2e**：结构化任务模型、专题 QA、知识覆盖与 synthetic 回归全部已具备，命中即挂载下游义务 (`extensions/*.json` + `topic-packs/` + `report.md` 专题小节)。
- **reference-only**：已有专题参考资料 (`references/ctf.md` / `game-reverse.md` / `malware-analysis.md`)，尚无 registry-backed 执行契约。
- 专题协议文档集中在 `references/`：静态分诊 `static-triage-playbook.md`；Web 套壳 `web-shell-triage.md` + `electron-playbook.md`；壳/脱壳 `packers.md` (VMP 另见 `vmp-unpack-playbook.md` / `vmp-devirt-playbook.md`)；反分析 `anti-obf.md` + `protection-bypass.md`；.NET `dotnet.md`；注入 `loader-injection.md`；TLS/网络 `tls-network-playbook.md`；驱动 `driver.md`；Frida `frida.md`；混合模式 `mixed-mode-interop-playbook.md`；IPC/持久化 `ipc-persistence-playbook.md`；异常/运行时 `exception-runtime-playbook.md`；内存取证 `memory-forensics-playbook.md`；协议/签名 `app-protocol.md`；配置/许可证恢复 `config-recovery.md`；UI 消息流 `ui.md`；drill 演练 `drill-playbook.md`。

文档地图

需要什么	去哪读
契约与词表 (唯一必读)	SKILL.md
最短上手路径	docs/guides/minimal-usage-manual.md
场景化提示词模板	PROMPTS.md
验收规则与词汇总表 (机器校验单源)	docs/reference/acceptance-criteria.md
执行协议与阶段语义	docs/reference/reverse-workflow.md / references/phase-gated-workflow.md
开局 / 续跑 / drill 引导	docs/reference/reverse-bootstrap.md
案例安全政策 / 纯提取任务	docs/reference/case-safety-policy.md / docs/reference/pure-extraction.md
多 Agent 协作协议	docs/reference/multi-agent-orchestration.md + agents/*.md
产物契约	docs/reference/output-contract.md / docs/reference/reverse-artifacts.md
环境搭建 / 工具链职责	references/setup-guide.md / references/tool-chains.md / docs/reference/tool-reference.md
反捷径 / 降级纪律	references/anti-shortcut-system.md / references/fallbacks.md
task-input 模板与 schema	references/task-input-template.md / references/schemas/win-reverse-task-input.schema.json
MCP 任务模板	references/mcp-task-template.md